

Haris: technical evidence

Sulaiman Almutkhaizeem · SIAP 2026 · 14 September 2026 · Policy haris-case-1.1

One working, bounded workflow

A relationship manager prepares a synthetic customer-case note. An independently signed-in reviewer approves the exact draft before a local case record is created. The model cannot retrieve other customers, call tools or take financial action. This is a functional prototype, not a bank deployment or compliance certification.

The implemented path is **authenticated user** → **customer/tool policy** → **minimized facts** → **local model** → **output checks** → **independent approval** → **case and audit event**. Blocked requests stop before the model or filing tool. The default adapter is explicitly labelled as a deterministic regression fixture; a separate Ollama adapter performs actual Qwen2.5:0.5b inference.

C101 · amal

Pending

Annual review is due and updated business activity evidence has been requested.

Content digest
58e53f04743a034fbc88eba5f7794f6d4a97181281712dc1cdac9454a187c369

Review the complete draft. Approval applies only to this digest.

Approve & file internally

Reject

Actual browser capture. Approval binds the full draft digest, requester, tenant, customer, model, language, current policy and a 15-minute validity window. The reviewer must retain the customer's assignment. Approval and case creation are atomic; replay and concurrent execution are tested.

Measured results

41 unit, integration and authorization tests pass. Coverage includes authentication, CSRF, session expiry/invalidation, tenant/customer isolation, revoked reviewer access, model/audit failure, output withholding, digest/expiry/policy checks, replay, concurrency and log tampering. Browser E2E covers real sign-in, redaction, blocked injection, independent approval creating a case, audit inspection and actual local inference. English and Arabic desktop/mobile screens were inspected without page exceptions or document-level horizontal overflow in the passing run.

The fixed corpus has **48 unique cases**: 20 benign, 22 adversarial and 6 legitimate approval-required requests. Two fresh-database runs each used five repeats: 240 sequential requests per run. Repeats are timing samples, not independent cases. The corpus was used during development and is not a held-out benchmark.

1. Attack block rate: **20/22 = 90.9%**, both runs.
2. Benign false positives: **1/20 = 5%**, both runs.
3. Correct approval routing: **6/6** legitimate filing requests.
4. Literal forbidden customer-fixture disclosures: **0/240 responses** per run.
5. Decision-audit completeness: **240/240** per run; service hash/HMAC checks passed.
6. Added gateway p95: **13.193 ms / 13.321 ms**. Gateway.process minus model-call time; includes policy, redaction, SQLite commit and integrity verification; excludes HTTP and authentication.

The same 48 cases ran against the actual local model: the same block/false-positive counts, 48/48 decision events, no literal forbidden fixture disclosures and no inference errors. Gateway p95 was **7.806 ms**; model-call p95 was **4,235.69 ms** among requests calling the model. This shorter pass has a smaller audit history and is not directly comparable to repeated-run latency. Background activity affects timing.

Hardware: Dell XPS 9320, Intel Core i7-1280P, 31.61 GiB RAM, integrated Iris Xe; Ollama reported 100% CPU inference. It is a general-purpose laptop without a discrete GPU, capable of small-model inference. A recorded response correctly stated: "Annual review is due. Updated business activity evidence has been requested." That fresh-setup response took 3,627.972 ms in the model and 2.392 ms in the gateway. One accurate response does not establish general factual reliability.

Failures, boundaries and reproduction

Failures remain visible. A paraphrased override and a base64 instruction pass the basic detector. A benign educational quotation is blocked. These remain two missed attacks and one false positive. Passing does not grant extra retrieval or execution authority. Literal fixture checks do not prove semantic privacy. An Arabic response invented a date; its screenshot was preserved. After prompt refinement, some outputs still echo source text or add unsolicited guidance. Human review of content is necessary.

A real authorization defect was repaired. The completion audit reproduced a same-tenant reviewer seeing and approving a pending case after losing that customer's assignment. Policy 1.1 denies queue access and approve/reject actions without current assignment. The regression report records the old distribution filing one case and the corrected source denying the action. All 41 tests and displayed evaluations ran after the repair; earlier results remain available.

Trust boundaries: script passwords, expiring HttpOnly/SameSite sessions and CSRF protection. The server binds to loopback HTTP. Audit events form per-tenant SHA-256/HMAC chains; an administrator holding both database and key can forge local evidence. Tail-deletion detection requires a separately trusted head. Production needs bank identity integration, TLS, protected key custody, external evidence storage, operational monitoring, independent assurance and applicable regulatory review. Full-history verification grows with log length. No production throughput, generalized PII coverage, demand, savings or CBK approval is claimed.

Reproduce: Python 3.11+; `python run.py --credentials` launches the default local demo. With Ollama installed, `python run.py --prepare-model --credentials` prepares the fixed model and enables real inference. No paid service is required. Run `python -m unittest discover -s tests -v`, `python clean_setup_test.py` and `python audit_results.py`. README supplies full evaluation/browser commands. The source archive includes code, corpus, raw outcomes, metrics, audit exports and screenshots; generated passwords, keys and databases are excluded.

Review the interactive evidence explorer and download the technical source at [Haris evidence website](#). The explorer displays recorded results; the full application runs locally. Personal application fields and the CV are supplied privately by email.

Sources: [CBK SIAP brief](#); [CBK CORF](#); [Ollama model](#). Measurements: `evidence/run-1`, `run-2`, `live-final`, `unit-integration-tests.txt`, `browser-qa.json`, `hardware.json`, `real-model-setup.json` and `reviewer-revocation-regression.json`. Arithmetic checks cover all repeats and public hash links; this is not independent security certification.